

safe

SecureSpeak: Knowledge-Augmented Phishing Detection for Mobile Financial Services in Bangladesh

Khondokar Sajid, Abdul Alim Rakib, Sumaya Shimu Rima, Shakib Ahamed

Department of Electrical and Computer Engineering, North South University, Dhaka, Bangladesh

Supervised by Dr. Nova Ahmed

Abstract

Mobile Financial Services (MFS) such as bKash, Nagad, and Rocket have become critical financial infrastructure in Bangladesh, yet their users—often elderly, first-time smartphone owners, or low-literacy remittance recipients—are disproportionately targeted by phishing and smishing attacks. Recent figures indicate that nearly one in ten MFS users has been victimized by fraud, with substantial average losses. Learned phishing detectors achieve high aggregate accuracy but systematically miss *brand-impersonation* attacks: newly registered domains that embed an MFS brand name (e.g., a fake bKash domain) yet appear structurally benign. We present SecureSpeak, a layered detection system that augments a learned URL classifier with a knowledge-based MFS brand-impersonation detector, a Bangla/Banglish smishing classifier, and a network-flow anomaly detector, and delivers bilingual low-literacy warnings. Our central result is that the knowledge layer recovers **[FILL: 99.3]**% of real MFS brand-impersonation phishing URLs that the learned URL model alone misses, on a set of **[FILL: 500+]** real MFS-brand phishing URLs—a class of zero-day attack that structure-based learned models cannot detect. We report component accuracies of **[FILL: 99.76]**% (URL) and **[FILL: 98.2]**% (Bangla SMS), and discuss deployment considerations for protecting vulnerable populations.

Keywords: phishing detection, mobile financial services, brand impersonation, usable security, Bangla NLP, smishing, zero-day, Bangladesh.

1 Introduction

[NOTE: Opening paragraph — the human stakes. Draft:] Mobile Financial Services (MFS) have transformed financial inclusion in Bangladesh, with bKash, Nagad, and Rocket serving a large share of the adult population. This growth has been accompanied by a surge in fraud: reported figures indicate roughly **[FILL: 9.3]**% of MFS users have been victimized, with an average loss of approximately **[FILL: Tk 9,000]** per victim, and a substantial fraction of non-users citing fraud fear as their reason for avoiding MFS entirely [1]. The users at greatest risk—elderly pensioners, first-time smartphone owners, and rural remittance recipients—are precisely those least equipped to recognize a fraudulent link or sender.

[NOTE: Second paragraph — the technical gap. Draft:] Learned phishing detectors report high aggregate accuracy, but

aggregate accuracy hides a dangerous blind spot. Structure-based models judge a URL by its lexical and host features; they therefore miss *brand-impersonation* attacks—newly registered domains that embed a trusted MFS brand name (for example, a fake domain containing bKash) while otherwise appearing clean. Because these domains are new, blacklists have not yet recorded them, and because they are structurally unremarkable, learned models score them as benign [2]. Real malware campaigns exploit exactly this gap: SikkahBot, active since 2024, impersonates official portals to target bKash, Nagad, and DBBL users while maintaining low detection rates [3].

[NOTE: Third paragraph — our approach. Draft:] We present SecureSpeak, a layered detection system designed for the MFS threat context. Its core insight is that a *small amount of authoritative knowledge*—the set of official MFS domains and package names—recovers an entire class of attacks that learned models miss. SecureSpeak combines four components: (i) a learned URL phishing detector; (ii) a knowledge-based MFS brand-impersonation detector; (iii) a Bangla/Banglish smishing classifier; and (iv) a network-flow anomaly detector for post-click malware, including unseen families. Detection results are delivered as bilingual (Bangla/English) warnings designed for low-literacy users.

[NOTE: Contributions list — keep concrete and honest:]
Contributions.

- A knowledge-based MFS brand-impersonation detector that recovers **[FILL: 99.3]**% of real brand-impersonation phishing URLs missed by a strong learned URL classifier, on **[FILL: 500+]** real MFS-brand URLs.
- A Bangla/Banglish smishing classifier (**[FILL: 98.2]**% accuracy), addressing an underserved language in security tooling.
- A deployable network anomaly detector operating on features available from on-device capture, with an honest treatment of domain shift.
- A bilingual, low-literacy warning design for vulnerable MFS users.
- An honest evaluation, including where each component fails, and explicit deployment limitations.

2 Background and Threat Model

[NOTE: Define the setting and who we protect. Draft:]

[[FILL: Figure 1: system architecture diagram — Claude will generate]]

Figure 1: SecureSpeak architecture: three detectors feed a decision layer that produces bilingual warnings.

2.1 Mobile Financial Services in Bangladesh

[[FILL: 2–3 sentences: MFS adoption scale; who the vulnerable users are.]]

2.2 Threat Model

We consider an attacker who seeks to steal MFS credentials (PIN/OTP) or induce fraudulent transfers through: (a) phishing URLs delivered via SMS or messaging apps; (b) Bangla/Banglish smishing messages; and (c) malicious applications that generate anomalous network activity after installation. We specifically consider *brand-impersonation* attacks, in which the attacker registers a new domain or app that mimics an official MFS brand. [NOTE: State clearly what is OUT of scope (honesty builds trust):] **Out of scope.** We do not address authorized-push-payment fraud, in which a user is socially engineered into willingly sending money; insider fraud at the operator level; or SIM-swap attacks. [[FILL: confirm this scope with Nova]]

3 System Design

[NOTE: Figure 1 = system architecture. I will generate this diagram.]

3.1 URL Phishing Detector

[NOTE: Draft — fill exact feature count/model:] The URL detector extracts [[FILL: 26]] lexical, structural, and MFS-specific features from each URL and classifies with a [[FILL: Random Forest (300 trees)]]. Trained on [[FILL: Stealth-Phisher2025 (150k URLs)]], it achieves [[FILL: 99.76]]% accuracy and [[FILL: 99.93]]% AUC under [[FILL: 5-fold]] cross-validation with the scaler fit inside each fold to prevent leakage.

3.2 MFS Brand-Impersonation Detector

[NOTE: THIS IS THE STAR. Explain it clearly. Draft:] The brand detector encodes authoritative knowledge: the set of of-

ficial MFS domains (e.g., `bkash.com`, `nagad.com.bd`) and Android package names. For an input URL, it (i) returns benign if the domain exactly matches an official domain; (ii) fires if an MFS brand token appears in a non-official domain; and (iii) fires on close lookalikes of an official domain by normalized edit distance. Crucially, this detector requires no training and generalizes instantly to newly registered domains—the zero-day case that defeats learned models.

3.3 Bangla/Banglish Smishing Detector

The SMS detector embeds each message with [[FILL: a multi-lingual MiniLM sentence encoder]] and concatenates [[FILL: 6]] handcrafted features (URL presence, MFS keywords, urgency markers), classified by [[FILL: logistic regression]]. On [[FILL: BanglaBarta2024 (4,374 messages)]] it achieves [[FILL: 98.2]]% accuracy. [NOTE: Justify MiniLM over BanglaBERT: smaller/faster for cheap phones.]

3.4 Network Anomaly Detector

[NOTE: Honest framing — deployable features + domain shift note. Draft:] The network detector operates on [[FILL: 11]] protocol-agnostic flow features (bytes, packets, duration, port, protocol, ratios) available from on-device capture, rather than lab-only feature sets. A supervised classifier scores known malware families; an isolation-based detector flags unseen (zero-day) families. We explicitly discuss domain shift between the training corpus and real Bangladeshi device traffic in Section 4.

3.5 Decision Layer and Bilingual Warnings

[NOTE: Keep this honest — describe as a lightweight fusion + 3-zone policy.] A lightweight decision layer combines detector outputs with deployment context (application trust, destination port) to produce one of three outcomes: SAFE (silent), DANGER (block with warning), or UNSURE (protect by default with a recognition-based prompt). Warnings are rendered in Bangla and English for low-literacy users. [NOTE: We do NOT claim this fusion beats an MLP on accuracy. Frame as a deployable, interpretable, updatable policy. This is the honest position.]

4 Evaluation

[NOTE: Lead with the STAR result — the brand rescue.]

4.1 Brand-Impersonation Rescue (Headline)

We evaluate on [[FILL: 500+]] real MFS-brand phishing URLs. Table 1 reports detection by the URL model alone, the brand detector alone, and their combination.

[NOTE: The one-sentence punch:] Of the [[FILL: 143]] URLs the learned model scored below threshold, the knowledge layer recovered [[FILL: 142]] ([[FILL: 99.3]]%)—

Table 1: Detection on real MFS brand-impersonation phishing URLs ($n = \text{[[FILL : 500]]}$).

Method	Detected (%)
URL detector (learned) alone	[[FILL: 71.4]]
Brand detector (knowledge) alone	[[FILL: 88.8]]
URL + Brand (SecureSpeak)	[[FILL: 99.8]]
Rescue rate on URL-model misses	[[FILL: 99.3]]

Table 2: Component detector performance.

Detector	Dataset	Acc. (%)
URL phishing	[[FILL: StealthPhisher2025]]	[[FILL: 99.76]]
Bangla SMS	[[FILL: BanglaBarta2024]]	[[FILL: 98.20]]
Network (known)	[[FILL: CICMalAnal2017]]	[[FILL: -]]

attacks that a structure-based model cannot detect because the domains are new and structurally benign.

4.2 Component Results

[NOTE: Compact table of the real detector numbers.]

4.3 Baseline Comparison

[NOTE: Run these on T4 — I’ll build the notebook. Honest framing: we MATCH strong learned baselines on accuracy, and ADD the brand-rescue capability they lack.] [[FILL: URLTran / BanglaBERT / MLP comparison numbers — from the baseline notebook]]

4.4 Honest Limitations of the Network Detector

[NOTE: Turn the domain-shift finding into an honest strength. Draft:] When applied to real Bangladeshi device traffic, the supervised network detector exhibits domain shift: benign local traffic scores higher than the Western training corpus’s benign class. We report this openly; the decision layer mitigates it by down-weighting network evidence for trusted applications, and we identify on-device fine-tuning as future work.

5 Discussion

[NOTE: What it means + who it helps. Keep honest.]

5.1 Why Knowledge Complements Learning

Learned models excel at the average case but cannot reason about novel brand-impersonation domains; a small authoritative knowledge base covers exactly that gap. The two are complementary, not competing.

5.2 Deployment Considerations

[NOTE: Sajid’s own honest point — state it:] At production scale, MFS operators could provide authoritative, signed domain and package lists, making the knowledge layer definitive. Our prototype uses a curated public whitelist, which we treat as a limitation rather than a contribution.

5.3 Limitations

- The brand whitelist is curated, not operator-signed.
- The network detector faces domain shift on real device traffic.
- Evaluation is on collected/public data; a user study of the warning interface is future work (a companion study is underway).
- [[FILL: any other honest limitation]]

6 Related Work

[NOTE: I’ll expand with real citations. Position against:]

- Bangladeshi MFS fraud detection, e.g., the CBF-SSL bKash SMS-fraud model [4] — we extend beyond SMS to URLs, network, and brand impersonation.
- Brand-domain features for phishing [2] — we show a knowledge layer recovers zero-day brand impersonation learned models miss.
- General phishing/smishing detection and usable security. [[FILL: more]]

7 Conclusion

[NOTE: Short, punchy, honest.] SecureSpeak shows that augmenting a learned phishing detector with a small authoritative knowledge base recovers a class of MFS brand-impersonation attacks that structure-based models systematically miss, while adding Bangla smishing detection and bilingual low-literacy warnings tailored to vulnerable users. [[FILL: one closing line tying back to the human stakes]]

Ethics and Data

[NOTE: Brief statement — public data, no PII, simulated where relevant.] All phishing URLs and SMS were obtained from public threat feeds and published datasets. No personally identifying user data was collected for this paper. [[FILL: confirm]]

[NOTE: Reference list — I will build refs.bib with real, verified citations:]

References

- [1] [[FILL: MFS fraud statistics source — verify and cite properly]]
- [2] A Study of Effectiveness of Brand Domain Identification Features for Phishing Detection, arXiv:2503.06487, 2025.
- [3] [[FILL: SikkahBot malware report — cite the CRIL/analysis source]]
- [4] [[FILL: CBF-SSL bKash SMS fraud paper — find full citation]]